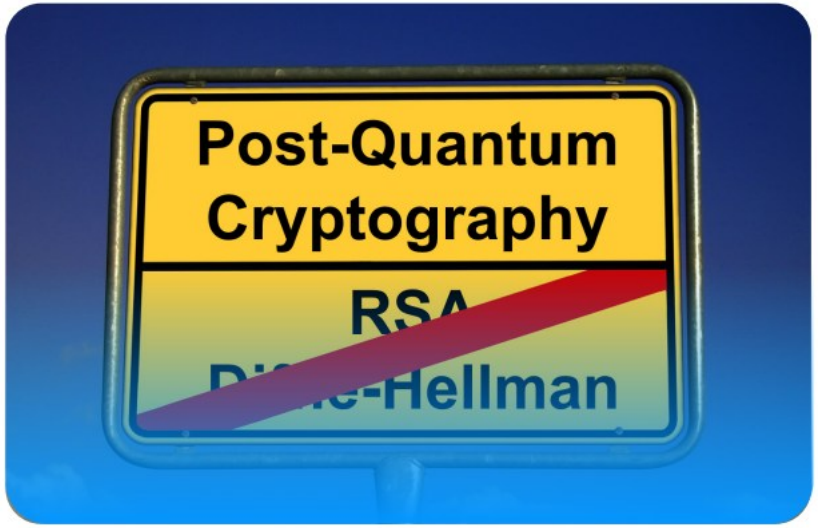


Постквантова криптография

Доц. М. Иванова

https://www.cryptovision.com/wp-content/uploads/2022/12/2022-12-16-Post-Quantum-Whitepaper-EN.pdf

https://www.nsa.gov/Cybersecurity/Post-Quantum-Cybersecurity-Resources/

https://www.epc.eu/content/PDF/2023/Cybersecurity_DP.pdf

Защо постквантова криптография?

- Като се има предвид, че RSA и Diffie-Hellman се използват милиарди пъти в уеб браузъри, смартфони, VPN клиенти и другаде, настоящото им приложение е тревожно. Например, хакер с квантов компютър може да изпразва онлайн банкови акаунти по желание или да декриптира криптирани имейли.
- Обаче, има много други асиметрични крипто методи освен RSA и Diffie-Hellman. Някои от тях не са податливи на квантовите компютри според съвременните познания.
- Те са групирани заедно под термина **постквантова криптография**.
- Първата важна задача за следващите няколко години е да се изследват по-нататък методите за постквантова криптография и да се подготвят протоколи за реално използване. Целта трябва да бъде да се заменят RSA и Diffie-Hellman възможно най-пълно.

Какво е квантова криптография?

- **Постквантовата** криптография не трябва да се бърка с квантовата криптография.
- Квантовата криптография има за цел да използва лазерна светлина за съгласуване на таен ключ между две станции без възможност за подслушване на линията - концепция, известна също като **квантово разпределение на ключове**.
- По този начин квантовата криптография предлага решение на проблема с обмена на ключове. Данните обикновено се предават чрез оптично влакно.

Какво е квантова криптография?

- Квантовата криптография няма нищо общо с квантовите компютри, освен че квантовата физика е основата и в двата случая.
- По-специално, квантовите компютри не са подходящи за използване като инструмент за атака на квантова криптография. Въпреки това, тъй като квантовата криптография не може да бъде атакувана с квантов компютър, тя може да се разглежда като част от постквантовата криптография.
- В сравнение с квантовите компютри, квантовата криптография е много по-лесна за внедряване и в някои случаи вече се предлагат устройства в търговската мрежа.

Постквантови криптографски методи

- През последните десетилетия са разработени над 100 криптографски метода, които се изследват дали са **квантово сигурни**. Много от тях показаха уязвимости в сигурността или се оказаха непрактични. Някои други постквантови методи досега са устояли на всички опити за атака.
- Оказа се, че почти всички **постквантови методи**, които са теоретично обосновани и могат да имат практическа реализация, принадлежат към едно от **шестте семейства алгоритми**, които се различават по своите математически основи:
  - **Алгоритми, базирани на решетка** (lattice-based): Тези методи работят в решетки с големи размери.
  - **Базирани на код алгоритми** (code-based): Методите от това семейство използват кодове за коригиране на грешки.
  - **Хеш-базирани алгоритми** (hash-based): Тези алгоритми са базирани на криптографски хеш-функции.
  - **Алгоритми, базирани на изогения** (isogeny-based): Методите от това семейство използват изогении между елиптичните криви.
  - **Многовариантни алгоритми** (multivariate): Многовариантните полиноми формират основата на тези алгоритми.
  - **Некомутативни алгоритми** (non-commutative): Тук некомутативните групи формират основата.

Постквантови криптографски методи

- **Некомутативни методи** - вече до голяма степен не се използват, след като твърде много методи от това семейство бяха атакувани и са разкрити несъвършенства.

Фигура: **Некомутативни криптографски методи** включват алгоритми подобни на куб на Рубик, наред с други техники. Това семейство постквантови методи не успя да получи признание поради опасения за сигурността.

Постквантови криптографски методи

- Повечето **многовариантни криптографски методи** също не издържаха на атаките на крипто аналитиците. Ето защо това постквантово семейство сега също се счита за несигурно.
- И тогава, през август 2022 г., за най-важния **изогенен метод** SIKE (Supersingular Isogeny Key Encapsulation) са установени уязвимости.
- Така, че все още има **три от постквантовите семейства,** които продължават да се считат за **сигурни**.
- Най-обещаващите несъмнено са методите, базирани на решетка (lattice-based), някои от които са се доказали като еднакво сигурни и практични.
- Ключовете при тези методи обикновено са значително по-дълги от тези на RSA и Diffie-Hellman.

Постквантови криптографски методи

- **Базираните на код и хеш методи** също имат добри свойства за сигурност, но се считат за тромави, защото изискват изключително дълги ключове или генерират изключително дълги подписи и понякога са доста бавни.
- В момента, тези **постквантови методи** вероятно ще служат предимно като алтернативни решения през следващите няколко години, ако човек не иска да разчита изключително на методите, базирани на решетка.
- И разбира се, всичко може да се окаже различно в крайна сметка - все пак никой не знае кои слаби места в кои методи ще открият експертите утре.

NIST постквантово състезание

- Американският институт NIST (Национален институт за стандарти и технологии) проведе няколко конкурса през последните десетилетия, за да намери най-добрия възможен криптографски метод за конкретна цел.
- Целта беше да се стандартизира най-добрият алгоритъм – сигурност, изпълнение, практичност.
- Състезанията на NIST винаги са имали голямо влияние върху развитието на криптографията. Например, AES се разпространи по целия свят, след като стана победител в състезание на NIST през 2000 г.
- През 2017 г. NIST стартира друго състезание. Този път целта е да се сравнят постквантовите крипто методи, за да се намери най-добрият.
- Експерти от цял свят са поканени да представят подходящи алгоритми, от които да бъдат избрани най-добрите методи в процес, продължил няколко години.
- Целта беше да се идентифицира портфолио от **висококачествени постквантови методи за различни цели и с различни математически основи**. Допустими за участие бяха както методи за електронен подпис, така и за криптиране и за обмен на ключове.

NIST постквантово състезание

- NIST допусна до състезанието 69 от представените методи. Много от методите се оказаха несигурни или неподходящи при по-внимателно разглеждане и поради това бяха елиминирани от надпреварата.
- След три кръга на оценка, NIST най-накрая обяви **четирима победители** през юли 2022 г.:
  - CRYSTALS-Kyber: Това е решетъчен метод за асиметрично криптиране.
  - CRYSTALS-Dilithium: Друг решетъчен метод, той се използва за цифров подпис.
  - FALCON: Този метод за цифров подпис също се основава на решетки.
  - SPHINCS+: Базираният на хеш SPHINCS+ е друг метод за подписване.
- Журито на NIST също така определи **четири допълнителни кандидата (т. нар. алтернативни кандидати)**, които да бъдат оценени в четвърти кръг.
- Оказва се, че първата група от победители съдържа три решетъчни системи, а всички алтернативни кандидати не са базирани на решетка: Classic McElliece, HQC и BIKE са кодови методи, докато SIKE е базиран на изогении. Последният беше прекратен за изследване през август 2022 г.

NIST постквантово състезание

- Покана за участие в състезанието **Кръг 1** – 2017 – 69 алгоритъма са изпратени
- **Кръг 2** – 26 алгоритъма:
  - Криптиране с публичен ключ и Алгоритми за установяване на ключ – 17 алгоритъма
  - Алгоритми за цифрово подписване – 9 алгоритми
- **Кръг 3** – 7 финалисти и 8 алтернативни кандидати
  - Криптиране с публичен ключ и Алгоритми за установяване на ключ – финалисти 4, алтернативни кандидати - 5
  - Алгоритми за цифрово подписване – финалисти 3, алтернативни кандидати 3
- **Кръг 4** – Изпратени - Криптиране с публичен ключ и Алгоритми за установяване на ключ – 4

NIST постквантово състезание

- **Избрани алгоритми 2022**
- Избрани алгоритми: Криптиране с публичен ключ и Алгоритми за установяване на ключ

Algorithm	Algorithm Information	Submitters	Comments
CRYSTALS-KYBER PQC License Summary & Excerpts	Zip File (7MB) IP Statements Website	Peter Schwabe Roberto Avanzi Joppe Bos Leo Ducas Eike Kiltz Tancrede Lepoint Vadim Lyubashevsky John M. Schanck Gregor Seiler Damien Stehle Jintai Ding	Submit Comment View Comments

NIST постквантово състезание

- **Избрани алгоритми 2022**
- Алгоритми за цифрово подписване

CRYSTALS-DILITHIUM	Zip File (11MB) IP Statements Website	Vadim Lyubashevsky Leo Ducas Eike Kiltz Tancrede Lepoint Peter Schwabe Gregor Seiler Damien Stehle Shi Bai

FALCON	Zip File (4MB) IP Statements Website	Thomas Prest Pierre-Alain Fouque Jeffrey Hoffstein Paul Kirchner Vadim Lyubashevsky Thomas Pornin Thomas Ricosset Gregor Seiler William Whyte Zhenfei Zhang

SPHINCS+	Zip File (230MB) IP Statements Website	Andreas Hulsing Daniel J. Bernstein Christoph Dobraunig Maria Eichlseder Scott Fluhrer Stefan-Lukas Gazdag Panos Kampanakis Stefan Kolbl Tanja Lange Martin M Lauridsen Florian Mendel Ruben Niederhagen Christian Rechberger Joost Rijneveld Peter Schwabe Jean-Philippe Aumasson Bas Westerbaan Ward Beullens

NIST постквантово състезание

- И накрая, NIST обяви ново състезание: Тъй като в предишния кръг не можеше да бъде препоръчан метод за подписване с кратки и бързо проверими подписи.
- Както и в миналото, решенията на NIST се очаква да имат голямо влияние в света на ИТ.
- Несъмнено различните печеливши процедури също ще бъдат включени в множество стандарти и продукти извън САЩ.
- В момента са стандартизирани 3 алгоритъма от постквантовата криптография - CRYSTALS-Kyber, CRYSTALS-Dilithium, SPHINCS+.

Стандарти - постквантова криптография

- През август 2024, NIST публикува един алгоритъм стандарт за установяване на ключове и криптиране:
  - CRYSTALS-Kyber
- и два алгоритъма стандарти за цифрово подписване:
  - CRYSTALS-Dilithium
  - SPHINCS+

https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography

Германската федерална служба за информационна сигурност и Орган за стандартизация на Интернет

- **Германската федерална служба за информационна сигурност** (German Federal Office for Information Security - BSI) също следи отблизо текущите разработки в квантовите изчисления и постквантовата криптография.
- Разбира се, експертите там първоначално се ръководят от състезанието NIST, резултатът от което също ще има голямо влияние в немскоезичния свят. BSI все още не е коментирала първите четири печеливши метода.
- За момента BSI в своя документ „Kryptographische Verfahren: Recommendations and Final Lengths“ препоръчва Classic McEliece и FrodoKEM.
- Classic McEliece е кодов метод и е един от четирите алгоритъма, който е алтернативен.
- FrodoKEM, друг решетъчен метод, от друга страна, е елиминиран от състезанието NIST за момента.

Германската федерална служба за информационна сигурност и Орган за стандартизация на Интернет

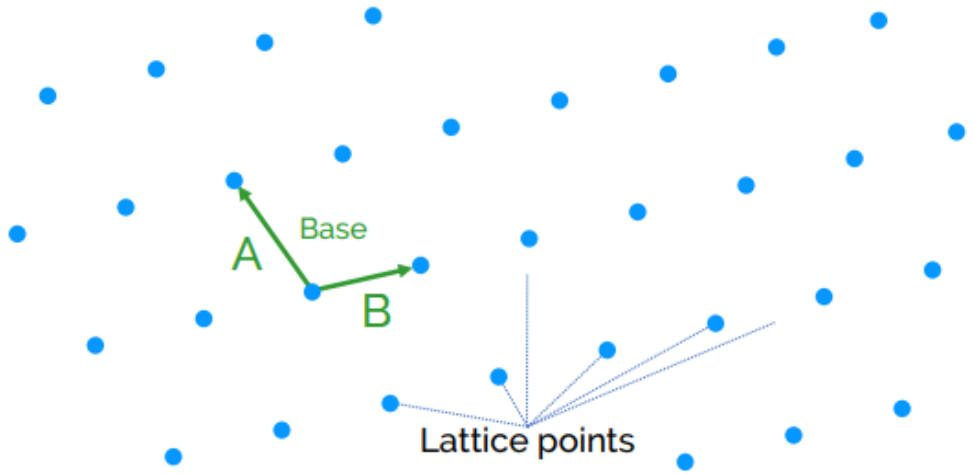
- Класическият McEliece и FrodoKEM се считат за консервативен избор. Нито един от двата метода не е сред най-практичните, но се представят много добре по отношение на сигурността.
- Класическият McEliece не е нов асиметричен метод. Тъй като никой не е открил слабо място за повече от четири десетилетия, може да се приеме, че е сигурен.
- Но, публичните ключове са почти 700 пъти по-дълги, отколкото при RSA.
- FrodoKEM също се счита за сигурен, но не можа да се задържи в състезанието NIST поради липса на ефективност.

Германската федерална служба за информационна сигурност и Орган за стандартизация на Интернет

- Internet Engineering Task Force (IETF), органът за стандартизация на Интернет, несъмнено също ще вземе пример от състезанието NIST.
- Въпреки това, вече има две „Искания за коментари“ (RFC), които уточняват постквантови процедури. Това са базираните на хеш процедури и са за цифрово подписване: XMSS (RFC 8391)(eXtended Merkle Signature Scheme) и Leighton-Micali (RFC 8554).
- Изборът на IETF също се счита за консервативен. Базираните на хеш методи е най-малко вероятно да имат открити уязвимости в сигурността в даден момент. Но, се характеризират с ниско ниво на ефективност.

Как работи базираната на решетка криптография?

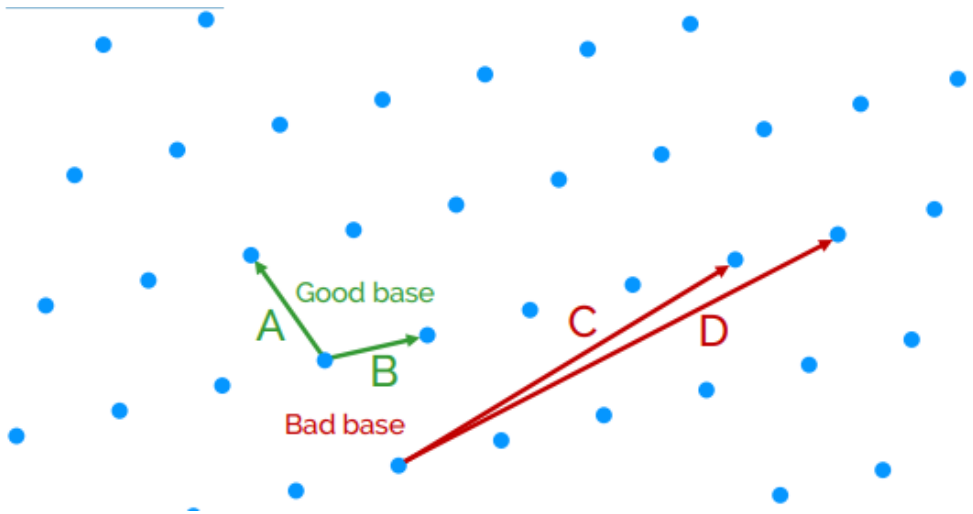
- **Решетки**
- Фигурата показва какво се разбира под **решетка** в математиката.
- В двумерното пространство дефиницията на решетка изисква два вектора, които тук са означени с A и B.
- A и B заедно образуват основа на решетката.
- Точките, които могат да бъдат достигнати с помощта на векторите, се наричат решетъчни точки.



Фигура: Тази решетка е дефинирана с двата вектора A и B, които заедно се наричат също основа. Точките, които се достигат чрез кратни на A и B, се наричат точки на решетката.

Как работи базираната на решетка криптография?

- Както е показано на Фигурата, винаги има няколко основи, които произвеждат една и съща решетка.
- Ако базовите вектори са почти перпендикулярни един на друг, това се нарича добра основа.
- Ако, от друга страна, те са почти успоредни, то се говори за лоша основа.



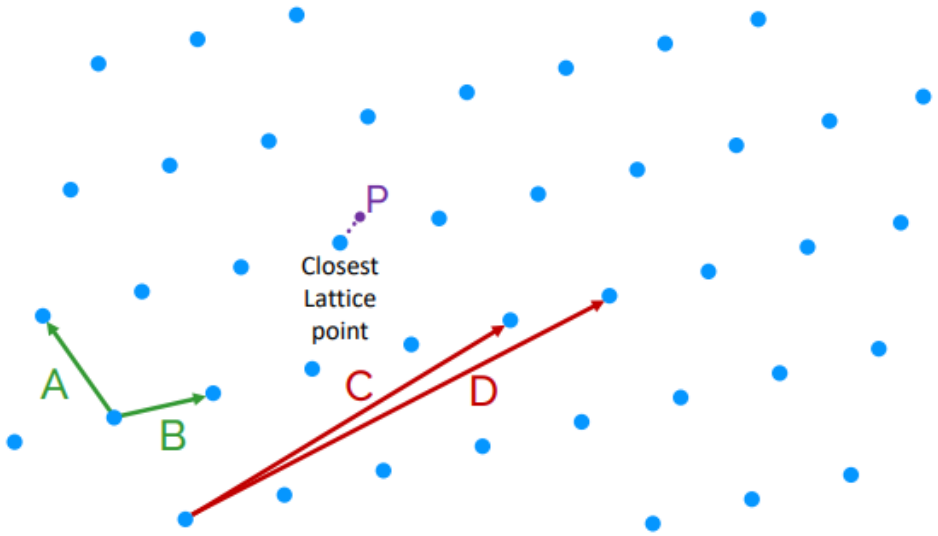
Фигура: Една решетка винаги може да бъде дефинирана с различни основи. Ако векторите на основата са приблизително перпендикулярни един на друг, тя се нарича добра основа; ако векторите са приблизително успоредни, това се нарича лоша основа.

Как работи базираната на решетка криптография?

- Може да се дефинира решетка в три измерения. За целта е необходима основа с три вектора, като третият не трябва да лежи в една равнина с другите два.
- В математиката човек не се задоволява с две или три измерения, а познава например и четири-, пет- или шестизмерни пространства. Човек не може да си ги представи, но може да извърши математически пресмятания в такива пространства доста добре.
- В постквантовата криптография дори се работи с няколкостотин измерения.
- Например там играят роля решетки в 500-мерно пространство, за чието дефиниране е необходима съответно база с 500 вектора. В такава многоизмерна среда човек може просто да изчисли и да различи лоша основа от добра. Обратният начин, от друга страна, е толкова сложен, че ще отнеме милиарди години дори с най-добрия компютър.

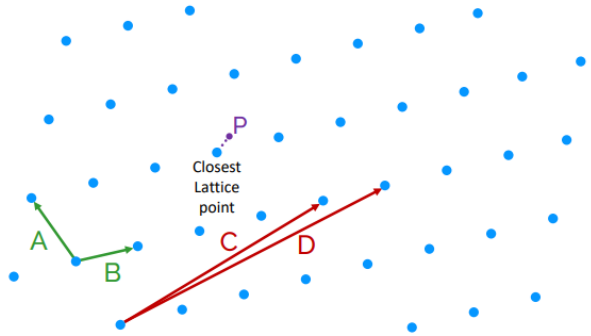
CRYSTALS-Kyber

- **Криптиране с CRYSTALS-Kyber**
- CRYSTALS-Kyber е един от четирите пост-квантови метода, обявени за победители в състезанието за 2022 г. от NIST.
- Това е единственият метод за **криптиране** в тази група и е предназначен като постквантова алтернатива на RSA.
- CRYSTALS-Kyber е базиран на метода на решетката и използва така наречения проблем за най-близкия вектор (вижте Фигурата). При това се приема, че точка P е дадена в решетката, но тя не е решетъчна точка.
- Въпросът е: Коя е най-близката точка на решетката до P?



Фигура: Дадена е точката P. Целта е да се намери най-близката точка на решетката до P. В двумерното пространство това е много просто. В 500-измерно пространство обаче подобно търсене е практично само с помощта на добра база.

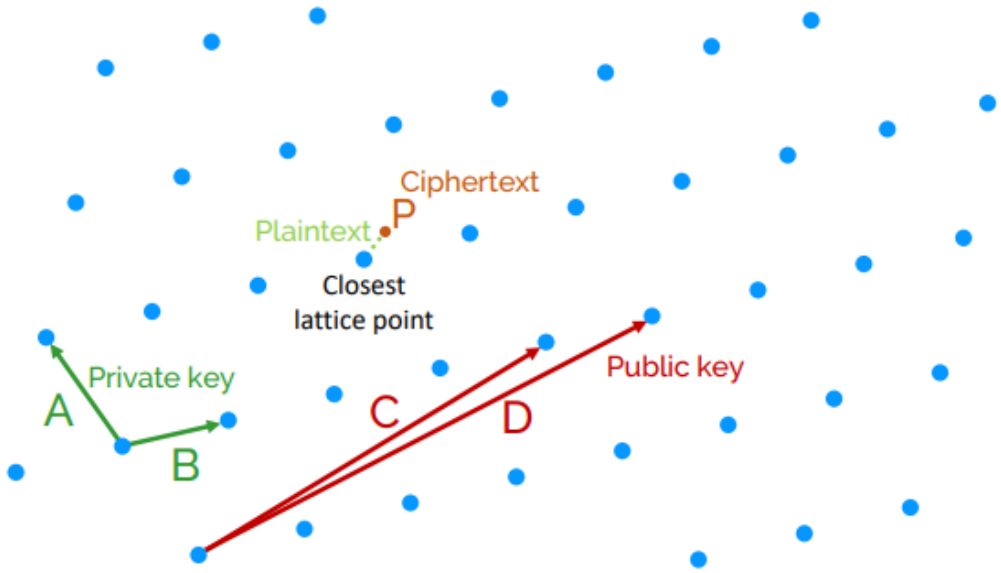
CRYSTALS-Kyber



- В двумерния случай задачата за най-близкия вектор е много лесна за решаване - P има само четири съседни точки и една от тях трябва да е най-близката.
- В 500-измерна решетка обаче нещата изглеждат различно. Тук една точка извън решетката има не по-малко от 2500 съседи.
- За намиране на най-близката точка се извършва следното: Ако е известна добра основа на решетката, компютърът може да намери най-близката точка на решетката за част от секундата, дори в пространства с големи размери.
- Ако, от друга страна, е налична само лоша база, тогава и най-силният компютър ще бъде затруднен в изчисленията.

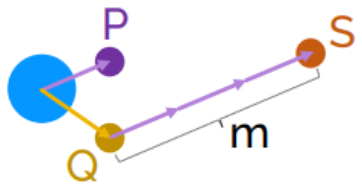
CRYSTALS-Kyber

- **CRYSTALS-Kyber** използва следния принцип.
- Добрата основа на решетката служи като частен ключ, докато публичният ключ се дава от лоша основа на същата решетка.
- За да криптира, изпращащият избира точка P в решетъчното пространство и в непосредствена близост до точка на решетката.
- Векторът между двете точки е явното съобщение. В 500-измерното пространство този вектор има 500 компонента, което е достатъчно за кодиране на 256-битово съобщение например. Точката P е криптограмата.
- Получателят може лесно да реконструира съобщението и по този начин да декриптира криптирания текст, като знае добра база, с която да изчисли точката на решетката, която е най-близо до криптирания текст.
- Атакуващият, от друга страна, разполага само с лоша база, което прави почти невъзможно определянето на въпросната решетъчна точка.



Фигура: За да криптира с CRYSTALS-Kyber, изпращащият избира точка P близо до точка на решетка. Векторът между двете точки е съобщението. P е криптираният текст.

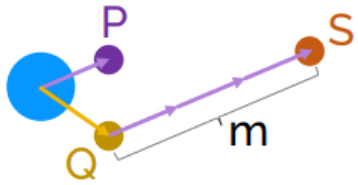
CRYSTALS Dilithium



- **Електронно подписване с CRYSTALS-Dilithium**
- **CRYSTALS-Dilithium** също е един от четирите алгоритми победители в състезанието NIST.
- Това е метод за цифрово подписване, който, подобно на CRYSTALS-Kyber, принадлежи към **решетъчните методи**.
- Въпреки това, разликите между CRYSTALS-Kyber и CRYSTALS-Dilithium са по-големи, отколкото подсказва общото CRYSTALS име.
- **CRYSTALS-Dilithium** също се основава на проблема за най-близкия вектор. Публичният ключ е точка P, която е близо до точка на решетка.
- Обърнете внимание, че атакуващият може да изчисли частния ключ от публичния ключ само ако реши проблема с най-близкия вектор, което фактически е невъзможно.

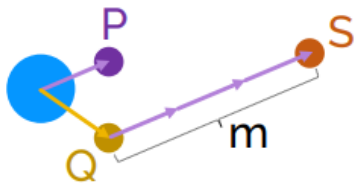
CRYSTALS Dilithium

- В този случай съобщението **m**, което трябва да бъде подписано, е число, например 3.
- За да го подпише, изпращащият избира втора точка извън решетката Q (вижте Фигурата), която също е близо до споменатата точка на решетката, и се изчислява S=Q +m·P. Получената точка S е електронният подпис.
- За да провери подписа, приемникът първо проверява дали S=Q+m·P е валидно.
- Освен това той измерва разстоянието между S и точката на решетката - ако това е толкова малко, че точката на решетката трябва да е най-близо до S, подписът е истински.



Фигура: В този случай съобщението, което трябва да бъде подписано, е число, например 3. За подписване изпращачът избира втора нерешетъчна точка Q, която също е близо до споменатата решетъчна точка, и изчислява S=Q+ m*P. Получената точка S е подписът.

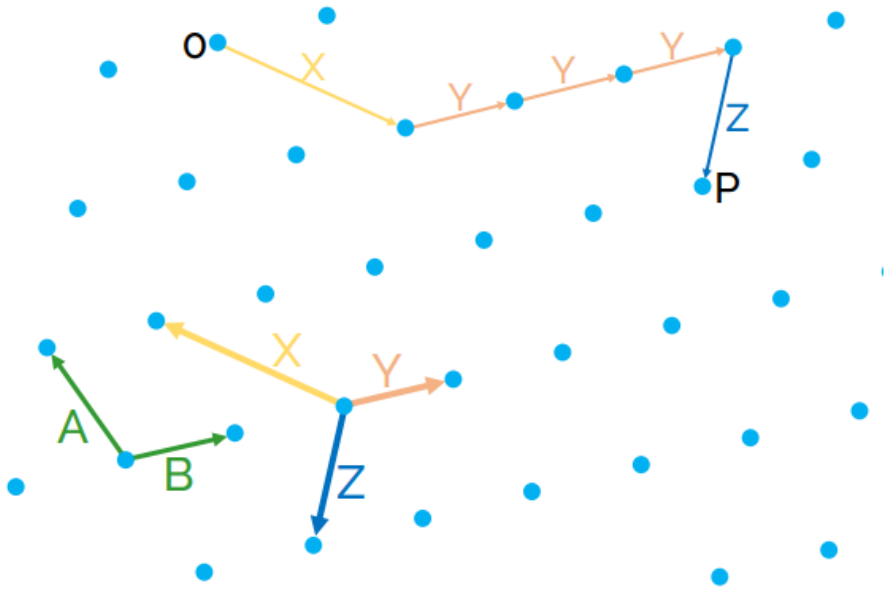
CRYSTALS Dilithium



- На фигурата тази криптографска схема работи само с малки числа за m.
- Ако се избере m=10 (голямо число), например, ще се приближите твърде много до други точки на решетката.
- Следователно, трябва да мислим, че разстоянията между точките на решетката в този случай са от порядъка на няколко километра, докато точките P и Q са само на милиметри от въпросната точка на решетката.
- В този случай съобщението m, което трябва да бъде подписано, може също да има стойност 100, без да се приближава твърде много до други точки на решетката.
- Освен това за приемника е относително лесно да прецени дали разстоянието между S и точката на решетката е достатъчно малко.
- Например, ако разстоянието е по-малко от 50 сантиметра, тогава подписът най-вероятно е истински, тъй като произволно избрана точка би се очаквало да бъде на няколкостотин метра.
- На практика разликите не са между сантиметри и километри, а няколко десетки порядъка повече.

FALCON

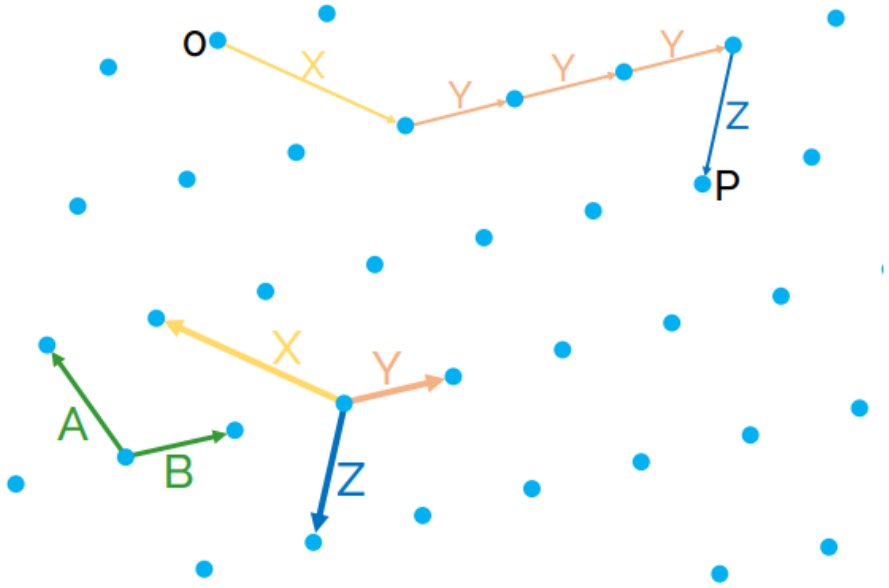
- **Електронно подписване с FALCON**
- **FALCON** е третият базиран на решетка метод, избран за победител в състезанието NIST, но не е стандартизиран.
- Това е метод за електронно подписване.
- **FALCON** се основава на проблем, показан на Фигурата.
- В допълнение към базовите вектори A и B тук се добавят вектори X, Y и Z. Броят на допълнителните вектори трябва да бъде по-голям от броя на базовите вектори.



Фигура: Тук въпросът е: Коя е най-късият път между 0 и P, ако само векторите X, Y и Z са разрешени като междинни стъпки

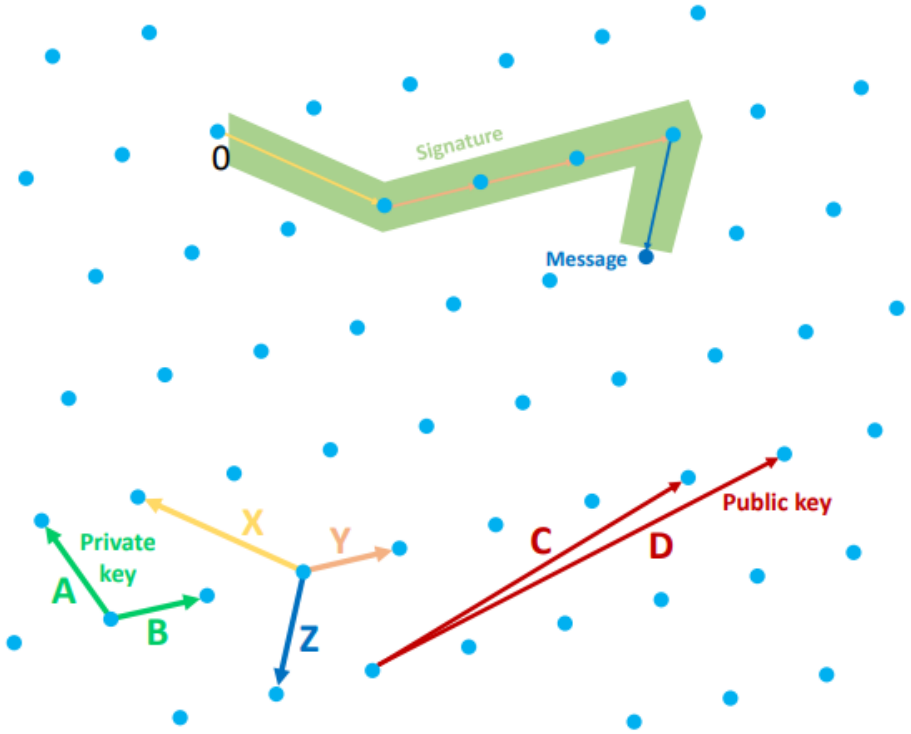
FALCON

- Ако сега разгледаме начална точка 0 на решетката, както и друга точка на решетката P, тогава въпросът е: **Коя е най-късата връзка между 0 и P, ако само векторите X, Y и Z са разрешени като междинни стъпки**?
- В двумерното пространство отговорът е лесен за намиране.
- В случая с 500 измерения, от друга страна: с добра основа, най-краткият път е сравнително лесен за изчисляване.
- С лоша база и на най-силния компютър му трябват милиарди и повече години.



FALCON

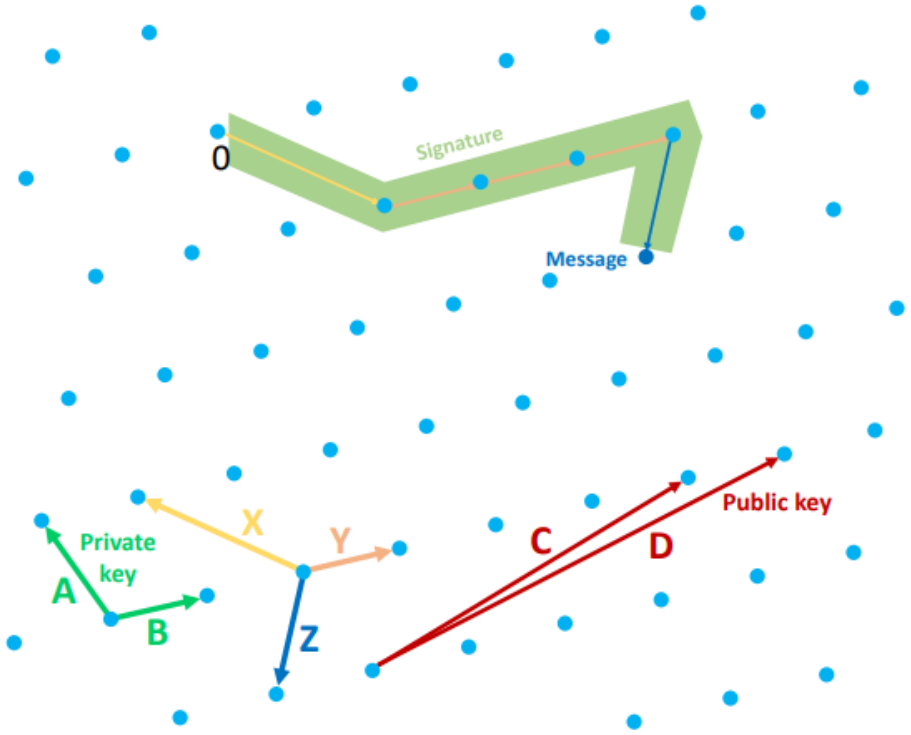
- Този принцип може да се използва за обяснение на процедурата за електронен подпис на **FALCON** (вижте Фигурата).
- В този случай частният ключ на получателя е решетка със свързана добра основа.
- Публичният ключ на изпращащия се дава от лоша основа на същата решетка.
- Сега, ако подателят иска да подпише съобщение, той го преобразува в решетъчна точка P. За да създаде подписа, подателят изчислява най-краткия път между 0 и P, което е доста лесно, тъй като той знае добра база. В примера този най-кратък път е -X+3Y+Z, така че подписът е -1, 3, 1.



Фигура: За да създаде подпис, изпращачът изчислява най-краткия път между 0 и P, което е доста лесно, тъй като знае добра база. Този най-кратък път в примера е -X+3Y+Z, така че подписът е -1, 3, 1.

FALCON

- Получателят на съобщението може да използва лошата база, за да провери дали подписът наистина води от 0 до P.
- За съжаление, той не може директно да провери дали това наистина е най-краткият път.
- Той обаче може да оцени дължината на най-краткия път въз основа на лесна за изчисляване формула и да я сравни с определената действителна дължина на пътя, представена като подпис. Ако разликата е достатъчно малка, подписът е истински.

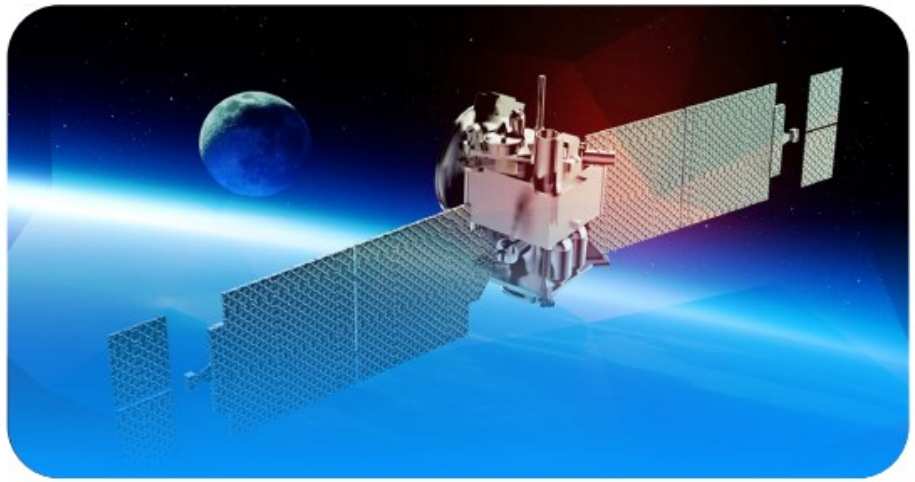


Хеш криптографски методи

- Фамилията **базирани на хеш криптографски методи** се различава в няколко отношения от другите пет описани постквантови фамилии.
- **Базираните на хеш методи** са сравнително математически прости.
- Те обаче могат да се използват само за цифрово подписване и не са подходящи за криптиране.
- Друга особеност е, че част от частния ключ трябва да бъде използвана за генериране на публична част за всеки подпис, което ограничава броя на подписите на ключ.
- Съображенията за сигурност са основните аргументи в полза на базираните на хеш методи.
- Тъй като методите в това семейство са възникнали през 70-те години на миналия век и следователно са сред най-старите асиметрични методи, те са добре проучени. Те дори са доказуемо сигурни при реалистични условия.

Хеш криптографски методи

- Базираните на хеш подписи се считат за тромави.
- Или дължината на подписа, или дължината на ключовете, или изчислителните усилия са твърде големи в ежедневната практика.
- Такива методи са следователно особено подходящи, когато подписването се извършва рядко, но се изисква особено висока и дългосрочна сигурност - например при защита на комуникация със сателити.



Хеш криптографски методи

- Основният принцип на **базираните на хеш подписи** не е сложен:
- 1. Подателят определя две произволни константи X и Y, всяка от които се състои от 256 бита, например X и Y образуват частния ключ.
- 2. Изпращащият прилага криптографска хеш функция H към X и Y. Резултатите A=H(X) и B=H(Y) формират публичния ключ.
- 3. Сега изпращащият подписва бит, както следва: Ако битът има стойност 0, той публикува X; ако, от друга страна, има стойност 1, публикува Y.
- Получателят **проверява** този подпис, както следва: Ако битът със знак има стойност 0, тогава той проверява дали A=H(X). В другия случай се проверява дали B=H(Y).

Хеш криптографски методи

- Този процес обаче отнема доста време - поради факта, че се подписва само един бит.
- Например, ако са подписани 256 бита, тогава подателят трябва да генерира 256 стойности всяка за X и Y, прилага се хеш функцията към всеки от тях и се публикуват 512 резултата като публичен ключ.
- В нашия пример това би дало дължина от над 131 000 бита всеки за частния и публичния ключ и това може да се използва само за едно съобщение.
- Самият подпис е наполовина по-дълъг от ключа, т.е. около 65 500 бита.
- За сравнение, RSA използва 2048 битов ключ и дължина на подписа. Има различни трикове, за да се направи тази процедура по-ефективна. Но те обикновено увеличават необходимото компютърно време.
- Друг недостатък: Тъй като всяка стойност на X и Y може да се използва само веднъж, подателят трябва да запомни кои стойности са били използвани и следователно да поддържа **съответен списък**. Няма такъв списък за използваните в момента криптографски методи.

SPHINCS+

- **Цифрово подписване със SPHINCS+**
- **Базираният на хеш метод** за цифров подпис **SPHINCS+** е друг победител в състезанието NIST.
- **SPHINCS+** се използва за генериране на електронни подписи.
- Чрез различни оптимизации разработчиците са успели да намалят размера на публичния и частния ключ до няколкостотин бита.
- В замяна подписът е с два порядъка по-дълъг, отколкото при RSA, а производителността е сред най-лошите от всички постквантови методи.

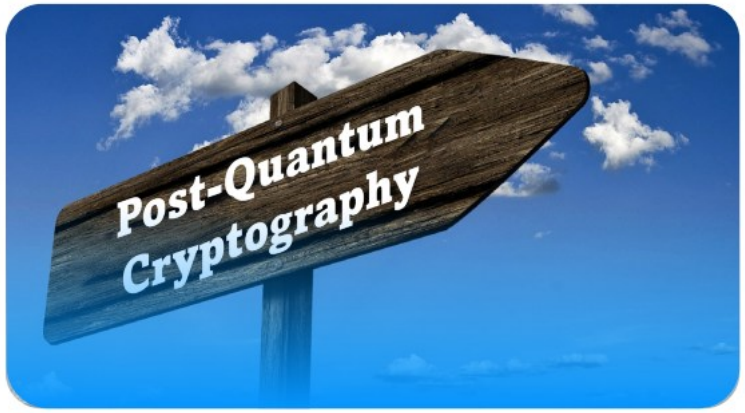
SPHINCS+

- Като метод, базиран на хеш, **SPHINCS+** всъщност ще се нуждае от списък с използвани ключове.
- Въпреки това, NIST иска да избегне трудностите, свързани с такъв списък от самото начало и следователно разрешава само алгоритми за подпис без списъци с използвани ключове.
- Следователно, **SPHINCS+** работи с допълнителен трик: предоставя много голям брой стойности за X и Y и осигурява механизъм, такъв че всяка от тях е избрана на случаен принцип.
- Ако числото е достатъчно голямо, вероятността ключът да бъде използван два пъти става незначителна.
- В резултат на това не е необходим списък с използвани ключове.
- Следователно, **SPHINCS+** отговаря на спецификациите на NIST.

XMSS и Leighton-Micali

- **Цифрово подписване с XMSS** и **Leighton-Micali**
- Органът за Интернет стандарти IETF вече също публикува **две схеми за подписване, базирани на хеш**:
  - **XMSS:** Разширената схема за подпис на Merkle (XMSS) е описана в RFC 8391.
  - **Leighton-Micali:** Тази процедура е специфицирана в RFC 8554.
- И двете процедури са публикувани като информационен RFC, което означава, че <u>нямат статут на официален стандарт</u>. Те обаче могат да се разглеждат като **квазистандарти**.
- **XMSS** и **Leighton-Micali** изискват списък, в който са отбелязани вече използваните ключове. Следователно, двата метода не биха били допустими за състезанието на NIST.

Бъдещето



- През следващите години ще продължи да бъде важно да се изучават **процедурите на постквантовата криптография**. Криптолозите несъмнено ще намерят много повече подобрения и ще открият уязвимости в процедурите, които преди са се считали за сигурни.
- **Стандартизацията** вече набра скорост с три от победилите алгоритми в NIST и двата RFC. Стандартизирането на процедурите е само първата стъпка.
- Във втората, те трябва да бъдат интегрирани в съответните формати и протоколи.
- Много експерти, включително отговорните специалисти от френския ANSSI (French Cybersecurity Agency)* и немския BSI**, предлагат използване на конвенционални техники за криптиране и постквантови процеси паралелно по време на преходната фаза.

*www.ssi.gouv.fr/en/publication/anssi-views-on-the-post-quantum-cryptography-transition
**www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Krypto/Post-Quanten-Kryptografie.pdf

Бъдещето

- Някои компании и организации вече са отговорили на квантовата заплаха.
- NSA (National Security Agency), например, обяви още през 2015 г., че ще се заеме с миграцията към постквантови алгоритми в близко бъдеще. Преди да бъдат въведени подходящите стандарти обаче, подобни стъпки носят риск да се подкрепи грешният алгоритъм.
- Освен това, основна задача ще бъде да се направят разнообразните и математически изключително взискателни постквантови методи достъпни за възможно най-голяма аудитория. Тъй като описанията на тези алгоритми, които са били налични досега в повечето случаи са разбираеми само за специалисти, е необходимо да се разработят по-добри описания.

Бъдещето

- И тогава многобройни предизвикателства се очакват, когато става въпрос за внедряване на постквантова криптография.
- Настоящите архитектури на чипове за смарт карти, например, са проектирани предимно за RSA или Diffie-Hellman и имат съответен копроцесор. За разлика от тях, те не са проектирани да изпълняват решетка или кодови операции, със сигурност не с необходимата дължина на ключовете. Следователно, **преразглеждането на настоящите архитектури на чипове** е важно предизвикателство за следващите години.
- Отдавна има множество изследователски проекти, проучващи използването на новите методи на практика. Сред най-важните е проектът Aquorypt („Приложимост на квантови компютърно-устойчиви криптографски методи“), който се занимава с внедряване на постквантови методи върху чип карти и във вградени системи. Подкрепя се от Германското федерално министерство на образованието и научните изследвания.
- Междувременно в IETF има няколко дейности, насочени към интегриране на постквантови методи в интернет протоколи.
- Инфраструктурите с публични ключове (PKI), включително X.509 и сертификати, които могат да се проверяват с карти, също трябва да станат постквантови.

Какво е криптографска гъвкавост?

- Дори когато първите формати за криптиране за Интернет бяха разработени, беше ясно: **използваните методи за криптиране трябва да бъдат взаимозаменяеми**.
- Очакваше се производителите на криптографски софтуер да дадат възможност на потребителя да избере предпочитаните от него криптографски алгоритми чрез конфигурационна настройка и да могат да включат допълнителни процедури в своите продукти по лесен начин. Така, можеше да се реагира бързо, особено ако дадена процедура се окаже несигурна.
- Този принцип вече се използва широко и е известен като криптографска гъвкавост.
- Например, повечето протоколи, използвани в Интернет, като TLS или IPsec, са крипто-гъвкави, което означава, че много реализации позволяват превключване от един криптографски метод към друг с едно щракване на мишката.
- Крипто-гъвкавостта се постига преди всичко от факта, че използваните крипто процеси не са фиксиран компонент на съответното решение, а са внедрени в независими модули и се извикват чрез точно определени интерфейси.

Какво е криптографска гъвкавост?

- В епохата на постквантовата криптография, крипто-гъвкавостта е по-важна от всякога. С оглед на заплахата, породена от квантовите компютри и факта, че през последните години бяха открити много уязвимости в постквантовите процедури, трябва да е възможно да се премине от една процедура към друга без големи усилия.
- Въпреки това, в ерата на постквантовата криптография също е по-голямо **предизвикателство** от всякога да се осигури крипто-гъвкавост.
- Това е така, защото различните постквантови методи имат различни свойства от RSA и Diffie-Hellman. Това е най-забележимо в ключовете, които често са многократно по-дълги в постквантовата криптография, отколкото в конвенционалните методи. Много протоколи не могат да се справят с това досега. Следователно за производителя на криптографски софтуер не е достатъчно просто да включи друга функция на библиотеката.
- В среди с бедни ресурси, ниската производителност на постквантовите методи, е пречка за реализиране на криптографска гъвкавост.

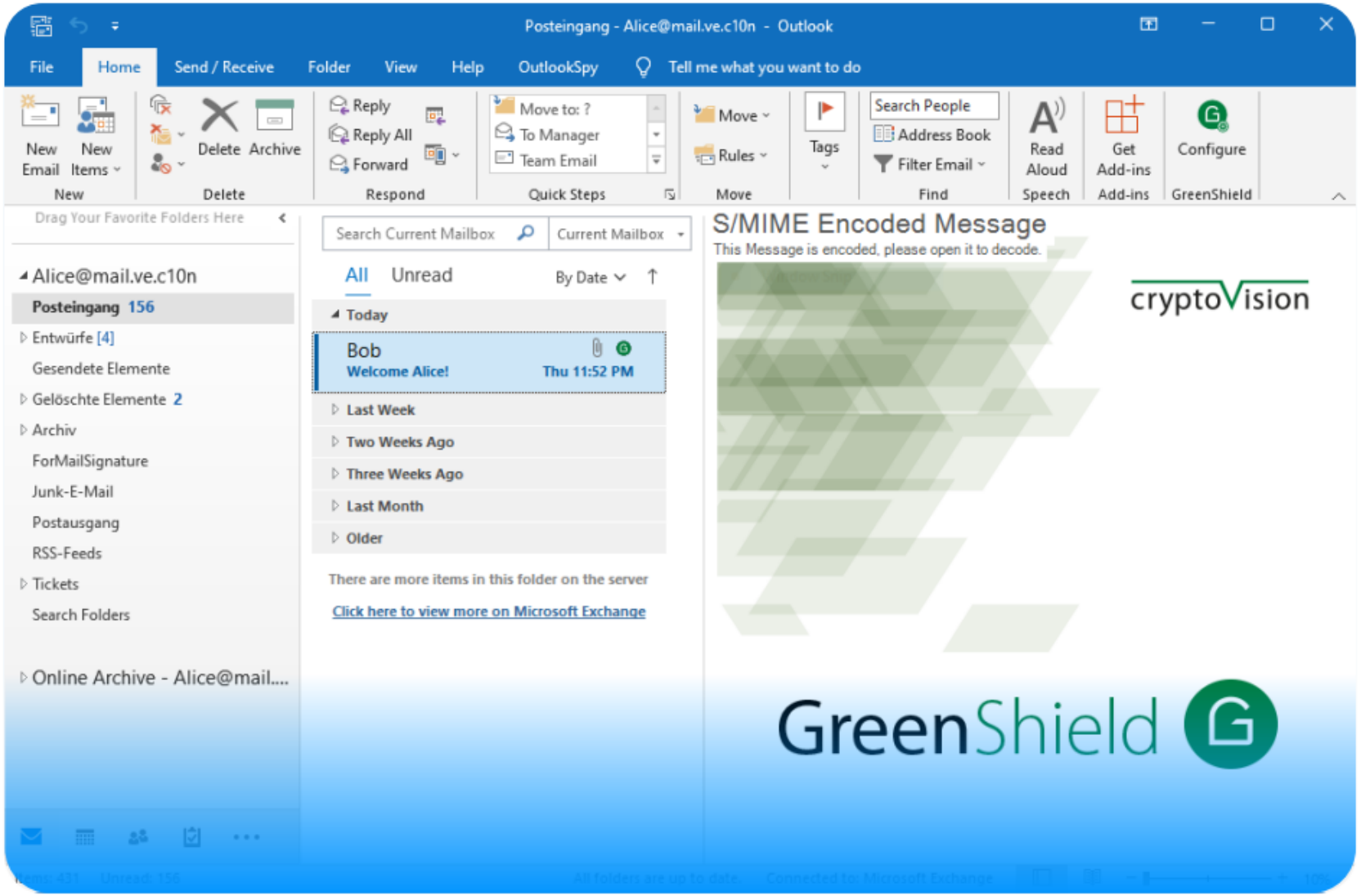
Какво е криптографска гъвкавост?

- Гореспоменатите списъци с използвани ключове, изисквани от някои от базираните на хеш методи, са друго **предизвикателство**. Това е така, защото много крипто решения не са настроени да съхраняват данни, които ще бъдат заявени при бъдещи крипто операции. Това може да повлияе на разпространението на такива методи.
- Следователно, **използването на постквантова криптография е неразривно свързано с парадигмата на крипто-гъвкавостта**.
- Несъмнено пазарът все повече ще изисква крипто-гъвкави решения и производителите ще трябва да се адаптират към това. Трябва да се разработят стандарти, критерии и сертификати.
- В допълнение, нарастващата необходимост от крипто-гъвкавост ще направи управлението на ключове в цялата организация още по-важно. Ако трябва да бъде въведен нов крипто алгоритъм или съществуващ да бъде премахнат, от решаващо значение е да имате преглед на това кое приложение какви методи използва и да разполагате със средства за лесна промяна на това.

Atos

- **Atos** е световен лидер в дигиталната трансформация със 107 000 служители и годишни приходи от над 11 милиарда евро.
- Atos е номер едно в света в управляваните услуги за сигурност и номер едно в Европа в областта на киберсигурността, облака и високопроизводителните изчисления.
- Atos предлага индивидуални решения от край до край за всички индустрии в 71 държави.
- От основаването си през 1999 г., Cryptovision, която беше придобита от Atos през 2021 г., се фокусира изключително върху **технологията за криптиране** и разработи, наред с други неща, доказаното, одобрено от VS-NfD GreenShield решение за защита на електронна поща и файлове (вижте Фигура 15 на следващия слайд).
- Компанията си създаде име в световен мащаб като експерт в сигурни, но лесни за потребителя решения за криптиране.

Atos

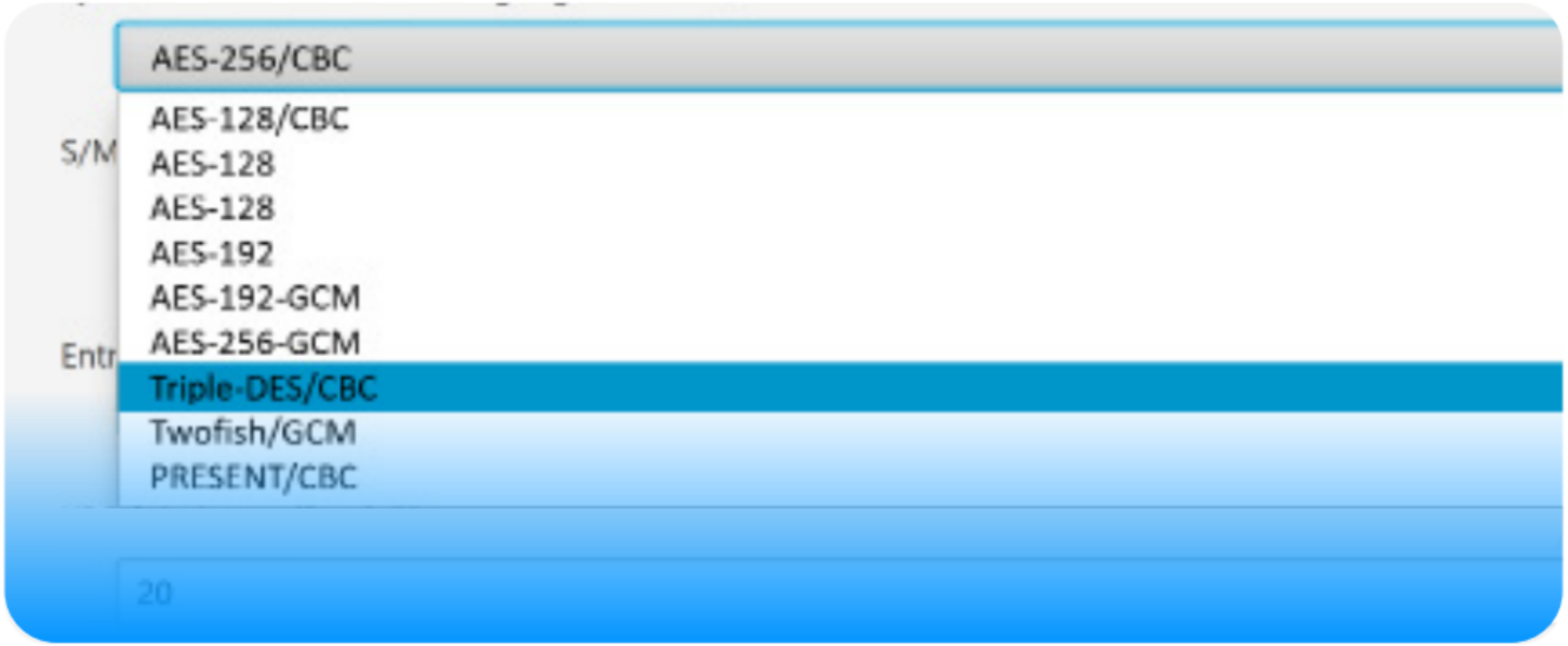


Фигура 15: Софтуерът Green Shield от Atos прави възможно криптирането на имейли по удобен за потребителя начин

Atos

- Atos вече се подготвя за следващото поколение технологии за криптиране и следователно разглежда и постквантовата криптография.
- Традиционно компанията е поставила голям акцент върху **крипто-гъвкавостта**. По този начин продуктите на компанията обикновено поддържат множество криптографски методи за една и съща цел, с възможност за превключване между тях с едно щракване на мишката (вижте Фигурата на следващия слайд).
- В допълнение, остарелите методи могат лесно да бъдат деактивирани и да бъдат включени нови. По този начин Cryptovision управлява прехода от RSA към ECC и от DES към AES.
- Преходът към **квантово безопасна криптография** може да се извърши с помощта на същите механизми. Веднага щом първите постквантови методи бъдат стандартизирани и готови за употреба, Atos веднага ще ги интегрира в съществуващите продукти по описания начин.

Atos



Фигура 16: Atos поставя голям акцент върху крипто гъвкавостта. Решенията на компанията обикновено поддържат множество криптографски методи за една и съща цел, като потребителят може да превключва между тях с едно щракване на мишката

Европейски съюз, квантови изчисления и постквантова криптография

- Тесният фокус на ниво ЕС върху това как да се смекчат краткосрочните предизвикателства за квантовата киберсигурност, особено „harvest attacks “ и квантовите атаки срещу криптирането, оставя държавите-членки като участници на първа линия в квантовия преход.
- Това може да създаде асиметрии между по-големите и по-малките държави, като по този начин отслаби общото ниво на киберсигурност в Европейския съюз.
- Към 2023 г. само няколко държави от ЕС са направили публични планове за противодействие на възникващи квантови заплахи за киберсигурността, а по-малко са въвели стратегии за смекчаването им, както в случая с Германия.
- Освен това бюджетът за киберсигурност и броят на наличните специалисти се различават между отделните държави, оставяйки по-малките държави с малко пространство и ресурси за обмисляне на смекчаване на възникващи заплахи.

Европейски съюз, квантови изчисления и постквантова криптография

- Докато страните подготвят своите структури за киберсигурност за квантови компютри, все още има въпроси кои технологии са по-добри за защита на информацията.
- Към днешна дата двете най-обещаващи са **квантовото разпространение на ключове** и **постквантовата криптография**, като и двете предлагат различен набор от предимства и недостатъци пред другите.

Препоръки за програма на ЕС за квантова киберсигурност

- 1. **Създаване на координиран план за действие на ЕС** относно квантовия преход, който очертава ясни цели и времеви рамки и наблюдава изпълнението на националните планове за миграция към пост-квантово криптиране.
- 2. **Създаване на нова експертна група** в рамките на Агенцията на Европейския съюз за киберсигурност (ENISA) с командировани национални експерти за обмен на добри практики и идентифициране на пречките пред **прехода към постквантово криптиране**.
- 3. **Подпомагане на определянето на приоритети за прехода към постквантово криптиране** и настояване за **криптографска гъвкавост**, за да се отговори на възникващи уязвимости в системите с постквантово криптиране.

https://www.enisa.europa.eu/

Препоръки за програма на ЕС за квантова киберсигурност

- 4. **Улесняване на политическата координация между Европейската комисия, държавите-членки на ЕС, националните агенции за киберсигурност и ENISA** за определяне на технологичните приоритети и идентифициране на подходящи случаи на използване на квантово безопасни технологии. Това е особено уместно във време, когато някои държави-членки индивидуално оценяват използването на постквантово криптиране, квантово разпределение на ключове или комбинация от двете.
- 5. **Улесняване на техническата координация на ниво ЕС** за справяне с **пропуските в научните изследвания** в **квантово сигурните технологии**.
- 6. **Проучване използването на пясъчни кутии** за ускоряване на развитието на краткосрочни приложения на квантовите информационни технологии.